ΘΕΜΑΤΙΚΕΣ ΠΕΡΙΟΧΕΣ ΕΚΠΟΝΗΣΗΣ ΠΤΥΧΙΑΚΩΝ ΕΡΓΑΣΙΩΝ

Επιβλέπων: Στυλιανός Καραγιάννης, Μεταδιδάκτωρ

Με την επιλογή της θεματικής ενότητας οι φοιτητές θα κληθούν προς συζήτηση της πτυχιακής και στην συνέχεια θα κληθούν να παραδώσουν τα παρακάτω:

- Μετά από συνάντηση με τον επιβλέποντα/την επιβλέπουσα, να προχωρήσει σε προσδιορισμό του ακριβούς αντικειμένου της πτυχιακής, εντός της επιλεγμένης θεματικής περιοχής.
- Πραγματοποίηση σύντομης επισκόπησης της θεματικής περιοχής και να αναπτύξουν μία σύντομη αναφορά (1-2 σελίδες) περιγραφής του θέματος της πτυχιακής.
- Πρόταση ενδεικτικής δομής της εργασίας και χρονοδιάγραμμα εκτέλεσης.
- Διαβάστε τον κανονισμό πτυχιακών για επιπλέον λεπτομέρειες (αριθμό σελίδων κλπ).
- Η συγγραφή προτείνεται να γίνει με Latex με βάση το template[1]. Σύντομες οδηγίες[2] για Latex.

Ενδείκνυται οι φοιτητές να έχουν καλή γνώση σε **λειτουργικά συστήματα** *(ενδεικτικά: Linux, Unix, Windows Powershell)*, **τεχνολογίες virtualization** *(ενδεικτικά: VirtualBox, VmWare, KVM, Proxmox)*, **δίκτυα** *(ενδεικτικά: βασικές εντολές, subnets, TCP/IP παραμετροποίηση, διαχείριση pcap files)* και **προγραμματισμό** *(ενδεικτικά: C, Python, PHP, GO, JAVA)*.

Ως εισαγωγικές έννοιες στην ασφάλεια, οι φοιτητές μπορούν να δουν ασκήσεις σε ανοικτές πλατφόρμες όπως το TryHackMe[3], HackTheBox[4], VulnHub[5], Academy-HTB[6].

Εισαγωγικά ξεκινήστε με TryHackMe, HackTheBox, δείτε βίντεο για επιθέσεις και εκτελέστε μερικές δικές σας επιθέσεις/ασκήσεις με VulnHub και Writeups (Video πχ με Vulnhub Raven[7]). Σημαντικό για να κατανοήσετε τις βασικές έννοιες. Για βασικό Linux ακολουθήστε οδηγίες για το Bandit.

- https://overthewire.org/wargames/bandit/
- https://www.hackingarticles.in/overthewire-bandit-walkthrough-1-14/

[1] https://www.overleaf.com/latex/templates/ionian-university-thesis/hcpvcfjmwmvn
[2] https://www.youtube.com/watch?v=s_InfVc1xJY
[3] https://tryhackme.com/
[4] https://www.hackthebox.com/
[5] https://www.vulnhub.com/
[6] https://academy.hackthebox.com/
[7] https://www.youtube.com/watch?v=FQHNn0IX6UQ

Επιπλέον, στην πορεία θα χρειαστεί να εγκαταστήστε το Virtualbox. Κατεβάστε το image από Parrot OS από τη σελίδα (Virtual / Security Version).

- https://parrotsec.org/download/

Διπλό κλικ και εισαγωγή το image στο Virtualbox. Αν έχετε Linux μπορείτε να εκτελέσετε κάποιες εντολές ωστόσο προτείνω το πειραματικό περιβάλλον (ParrotOS) να είναι σε Virtual Machine για να μην έχετε προβλήματα. Για MACOS προτείνω UTM αντί για Virtualbox, ότι σας εξυπηρετεί όμως.

Ως εισαγωγικές έννοιες στην ασφάλεια, οι φοιτητές μπορούν να δουν ασκήσεις σε ανοικτές πλατφόρμες όπως το TryHackMe[1], HackTheBox[2], VulnHub[3], Academy-HTB[4].

Εισαγωγικά ξεκινήστε με TryHackMe, HackTheBox, δείτε βίντεο για επιθέσεις και εκτελέστε μερικές δικές σας επιθέσεις/ασκήσεις με VulnHub και Writeups (Video πχ με Vulnhub Raven[5]). Σημαντικό για να κατανοήσετε τις βασικές έννοιες.

[1] https://tryhackme.com/
[2] https://www.hackthebox.com/
[3] https://www.vulnhub.com/
[4] https://academy.hackthebox.com/
[5] https://www.youtube.com/watch?v=FQHNnoIX6UQ

Επιπλέον δείτε τα εξής για να κατανοήσετε πως λειτουργούν τα εικονικά συστήματα.

- https://www.youtube.com/watch?v=uh-j_YubHbs
- https://www.youtube.com/watch?v=XCkKDWMYHME
- https://www.youtube.com/watch?v=Q85ku046Q_E

Ακολουθούν τίτλοι και περιγραφές πτυχιακών εργασιών και έπειτα οι ευρύτερες θεματικές περιοχές για να κατανοήσετε ευρύτερα το επιστημονικό πεδίο (επιλέγετε προσεγγιστικά σε ότι σας ενδιαφέρει περισσότερο και το συζητάμε).

---

1. LLM για Κυβερνοασφάλεια & Ανάλυση Κινδύνων

Εστίαση: Αξιοποίηση Μεγάλων Γλωσσικών Μοντέλων (LLMs) για ανίχνευση, εκτίμηση ή μετριασμό απειλών ασφάλειας.

- **LLM-Tutor** – Παιχνιδοποιημένο σύστημα εκπαίδευσης στην κυβερνοασφάλεια που προσφέρει διαδραστικά σενάρια και μετρήσεις επίδοσης μέσω dashboards. *Μεθοδολογία:* Ανάπτυξη εκπαιδευτικών σεναρίων με LLM, συλλογή δεδομένων επίδοσης και αξιολόγηση μέσω μικτών μεθόδων (ποσοτική ανάλυση – ποιοτικά σχόλια χρηστών).
- **LLM-Vuln** – Πλατφόρμα αποτύπωσης και αξιολόγησης ευπαθειών με χρήση LLMs που παράγει αναφορές κινδύνου και οπτικοποιήσεις. *Μεθοδολογία:* Fine-tuning σε δεδομένα CVE, αυτόματη ανάλυση περιγραφών συστημάτων και σύγκριση αποτελεσμάτων με παραδοσιακούς vulnerability scanners.

- **Garak LLM Vuln Lab** – Εργαστηριακό περιβάλλον για δοκιμή επιθέσεων σε LLMs, όπως prompt injection ή adversarial input.
  Μεθοδολογία: Red-team/blue-team πειράματα, adversarial testing και ανάλυση ανθεκτικότητας των μοντέλων υπό ελεγχόμενες συνθήκες.

- **LLM-Phish** – Δημιουργία σεναρίων phishing μέσω LLM για εκπαίδευση προσωπικού και ευαισθητοποίηση σε κυβερνοαπειλές.
  Μεθοδολογία: Generative prompting για παραγωγή email/μηνυμάτων, αυτόματη αξιολόγηση (click rates, response time) και ποιοτική ανάλυση συμπεριφορών.

- **Secure Mailservers LLM** – Χρήση LLM για ενίσχυση της ασφάλειας mail servers και ανίχνευση κακόβουλων ή πλαστών μηνυμάτων.
  Μεθοδολογία: Εκπαίδευση σε datasets phishing/spam, ενσωμάτωση σε mail gateway και συγκριτική αξιολόγηση με φίλτρα όπως SpamAssassin.

- **LLM-NFlowsL** – Ανάλυση δικτυακής κίνησης με LLMs για εντοπισμό ανωμαλιών και υποστήριξη IDS.
  Μεθοδολογία: Feature extraction από pcap αρχεία, περιγραφική ερμηνεία μέσω φυσικής γλώσσας και αξιολόγηση με datasets όπως CIC-IDS-2017.

2. Παιχνιδοποίηση στην Εκπαίδευση & Κατάρτιση στην Κυβερνοασφάλεια

Εστίαση: Εκμάθηση μέσω παιχνιδιών, προσομοιώσεων και διαδραστικών περιβαλλόντων για ενίσχυση της επίγνωσης και αλλαγή συμπεριφορών.

- **Cybersecurity Chatbot Training** – Διαδραστικό chatbot με σενάρια κυβερνοασφάλειας και στοιχεία παιχνιδοποίησης (πόντοι, επίπεδα, badges).
  Μεθοδολογία: Ανάπτυξη conversational agent με LLM, δοκιμές με χρήστες και αξιολόγηση engagement/μάθησης.

- **Bitsy Security Quests** – Δημιουργία μικρών παιχνιδιών (quests) ασφάλειας με το εργαλείο Bitsy.
  Μεθοδολογία: Game design, iterative testing, συλλογή δεδομένων (χρόνοι, επιτυχία, εμπλοκή) και ανάλυση εμπειρίας χρήστη.

- **DeepFake Awareness Games** – Εκπαιδευτικά παιχνίδια για εντοπισμό deepfake περιεχομένου και κατανόηση παραπληροφόρησης.
  Μεθοδολογία: Δημιουργία deepfake δειγμάτων, σχεδίαση παιχνιδιού αναγνώρισης και αξιολόγηση ακρίβειας – αλλαγής στάσης χρηστών.

- **Cyber Escape Rooms** – Ψηφιακά escape rooms με θέματα κυβερνοασφάλειας, όπως αποκωδικοποίηση, επιθέσεις phishing ή ransomware.
  Μεθοδολογία: Σχεδίαση σεναρίων, δοκιμές σε ομάδες και ανάλυση χρόνων/στρατηγικών επίλυσης.

- **Cyber Training Games** – Εκπαιδευτικά σενάρια κυβερνοασφάλειας σε πλατφόρμες τύπου Adeptly.ai για επαγγελματική κατάρτιση.

Μεθοδολογία: Ανάπτυξη σεναρίων, A/B testing, συλλογή metrics μάθησης και βελτίωση μοντέλου μάθησης.

- **Interactive Cyber Books** – Διαδραστικά βιβλία που συνδυάζουν αφήγηση, κουίζ και αποφάσεις για θέματα ιδιωτικότητας/ασφάλειας.
  Μεθοδολογία: Δημιουργία branching storylines, usability testing και μετρήσεις γνωστικής μάθησης.
- **Social Lab Privacy Wargame** – «Πολεμικά παιχνίδια» για ιδιωτικότητα/ασφάλεια με υποστήριξη LLM για αυτόματη παραγωγή σεναρίων.
  Μεθοδολογία: Σχεδίαση ρόλων, αυτοματοποίηση καταστάσεων με LLM, καταγραφή και ανάλυση στρατηγικών αποφάσεων παικτών.

3. Υποδομές, Εργαλεία & Παρακολούθηση Ασφάλειας

Εστίαση: Ανάπτυξη αυτοματισμών, εργαλείων και πλατφορμών για επιχειρησιακή άμυνα και παρακολούθηση συστημάτων.

- **n8n/Haystack SecOps** – Αυτοματοποίηση ροών ασφαλείας (security workflows) και ευφυής αναζήτηση δεδομένων περιστατικών.
  Μεθοδολογία: Ενσωμάτωση n8n και Haystack, σχεδιασμός pipelines για ειδοποιήσεις, συλλογή logs και αξιολόγηση χρόνων απόκρισης.
- **Shodan + ZoomEye/Fofa Analysis** – Ανάλυση εκτεθειμένων υποδομών στο διαδίκτυο και χαρτογράφηση πιθανών στόχων.
  Μεθοδολογία: API querying, data aggregation, γεωγραφική οπτικοποίηση (π.χ. με Kibana ή Grafana) και ανάλυση επιφανειών επίθεσης.
- **Sigma Rules to ELK + n8n** – Ενσωμάτωση κανόνων Sigma στο οικοσύστημα ELK για αυτόματη ανίχνευση απειλών και αυτοματοποίηση.
  Μεθοδολογία: Μετατροπή κανόνων σε queries ELK, δοκιμές με simulated attacks και pipeline αυτοματισμού με n8n.

4. Ασφάλεια Κυβερνο-Φυσικών Συστημάτων & Ψηφιακών Διδύμων

Εστίαση: Εφαρμογή κυβερνοασφάλειας σε συστήματα IoT, ενέργειας και προσομοιώσεις ψηφιακών διδύμων.

- **LabShock Digital Twin** – Ψηφιακός δίδυμος ενεργειακού συστήματος με LLM για προσομοίωση κυβερνοεπιθέσεων και απόκρισης.
  Μεθοδολογία: Δημιουργία twin μοντέλου, προσομοίωση επιθέσεων (DoS, spoofing), χρήση LLM για ανάλυση συμβάντων.
- **IoT Cyber Range** – Εκπαιδευτικό περιβάλλον που προσομοιώνει επιθέσεις και άμυνες σε IoT συσκευές.

Μεθοδολογία: Ανάπτυξη εικονικών κόμβων IoT, χρήση containers, εκτέλεση επιθέσεων/ανίχνευσης και αξιολόγηση εκπαιδευτικής αξίας.

- **Unity + Digital Twin** – Προσομοίωση με Unity για εκπαίδευση στην ασφάλεια ψηφιακών διδύμων.
  Μεθοδολογία: Ανάπτυξη 3D περιβάλλοντος, ενσωμάτωση συμβάντων ασφαλείας και μετρήσεις αντίδρασης/μάθησης χρηστών.

5. Ιδιωτικότητα, Ευαισθητοποίηση & Ανάλυση Συμπεριφοράς

Εστίαση: Μελέτη ανθρώπινης συμπεριφοράς, ανάλυση κινδύνων ιδιωτικότητας και ανάπτυξη τεχνολογιών προστασίας.

- **Smartphone Privacy & PETs** – Ανάπτυξη και δοκιμή Privacy-Enhancing Technologies (PETs) σε smartphones.
  Μεθοδολογία: Υλοποίηση πρωτοτύπου app, χρήση differential privacy/anonymization και αξιολόγηση σεναρίων χρήσης.
- **Browser History Behaviour Analysis** – Ανάλυση ιστορικού περιήγησης για πρόβλεψη συμπεριφοράς και κινδύνων ιδιωτικότητας.
  Μεθοδολογία: Εξαγωγή χαρακτηριστικών από logs, ανάλυση με ML και στατιστική συσχέτιση με προφίλ χρήστη.
- **Monitor Android Traffic – LLM4Privacy** – Παρακολούθηση και ανάλυση δικτυακής κίνησης Android με LLMs για προστασία ιδιωτικότητας.
  Μεθοδολογία: Συλλογή δεδομένων με packet capture, φυσική περιγραφή ροών από LLM και αξιολόγηση ακρίβειας εντοπισμού κινδύνων.

1. Χρήση της Πλατφόρμας Bitsy για Εκπαίδευση σε Cybersecurity Awareness και Privacy

Η παρούσα εργασία εστιάζει στην ανάπτυξη και αξιολόγηση διαδραστικού εκπαιδευτικού υλικού για την ενίσχυση της ευαισθητοποίησης σε θέματα κυβερνοασφάλειας (Cybersecurity), ασφάλειας πληροφοριών (Security Awareness) και προστασίας προσωπικών δεδομένων (Privacy). Η ανάγκη για συνεχόμενη εκπαίδευση και ενημέρωση σε αυτά τα πεδία είναι επιτακτική, καθώς οι σύγχρονες ψηφιακές απειλές γίνονται ολοένα και πιο πολύπλοκες και συχνές.

Για την επίτευξη αυτού του στόχου, αξιοποιείται η πλατφόρμα Bitsy, μια εύχρηστη ψηφιακή πλατφόρμα δημιουργίας μικρών διαδραστικών ιστοριών και παιχνιδιών. Μέσω αυτής, σχεδιάζονται εκπαιδευτικά σενάρια που προσομοιώνουν ρεαλιστικές καταστάσεις ασφάλειας, όπως phishing, διαχείριση κωδικών και προστασία προσωπικών δεδομένων.

Η διαδραστική μορφή των σεναρίων επιτρέπει στους χρήστες να εμπλακούν ενεργά και να αποκτήσουν βιωματική γνώση, αυξάνοντας την αποτελεσματικότητα της εκπαίδευσης σε σύγκριση με τις παραδοσιακές μεθόδους. Η εργασία περιλαμβάνει την υλοποίηση των σεναρίων,

την αξιολόγηση της απόδοσής τους και την ανάλυση των αποτελεσμάτων για τη βελτίωση μελλοντικών εκπαιδευτικών εργαλείων στον τομέα της κυβερνοασφάλειας.

2. Προσομοίωση εκστρατείας στοχευμένου phishing (spearphishing) με χρήση Large Language Models (LLMs) και τεχνικών κοινωνικής μηχανικής

Μελετά την κατασκευή εκστρατείας spearphishing αξιοποιώντας LLMs για τη δημιουργία εξατομικευμένου και πειστικού phishing περιεχομένου. Περιλαμβάνει τεχνικές OSINT για τη συλλογή δεδομένων στόχων και τη δημιουργία "personas" (μπορεί να γίνει χρήση Maltego κλπ). Εξετάζεται ο τρόπος που τα LLMs μπορούν να ενισχύσουν την κοινωνική μηχανική, ενώ παρέχεται τεκμηριωμένο εκπαιδευτικό σενάριο με παραδείγματα, prompts και παραγόμενα emails.

3. Shodan και ZoomEye/Fofa για την Ανάλυση Εκτεθειμένων Υποδομών στο Διαδίκτυο

Η συνεχής αύξηση των διασυνδεδεμένων συσκευών και υπηρεσιών στο Διαδίκτυο αυξάνει και τους κινδύνους έκθεσης ευάλωτων υποδομών σε κακόβουλες επιθέσεις. Η αναγνώριση και ανάλυση εκτεθειμένων πόρων αποτελούν κρίσιμο βήμα για τη διαχείριση της ασφάλειας και την πρόληψη επιθέσεων.

Η παρούσα ενότητα εστιάζει στα εργαλεία Shodan, ZoomEye και Fofa, τα οποία αποτελούν εξειδικευμένες μηχανές αναζήτησης και συλλογής πληροφοριών (Internet-wide scanners). Αυτά τα εργαλεία επιτρέπουν την ανάλυση, εντοπισμό και χαρτογράφηση εκτεθειμένων συσκευών, υπηρεσιών και εφαρμογών που είναι προσβάσιμες μέσω διαδικτύου. Το Shodan, το ZoomEye και το Fofa προσφέρουν δυνατότητες ανίχνευσης βάσει IP, θύρας (port), πρωτοκόλλου και άλλων χαρακτηριστικών, ενώ παράλληλα επιτρέπουν την αξιολόγηση πιθανών ευπαθειών. Μέσω της χρήσης τους, μπορεί να δημιουργηθεί μια σφαιρική εικόνα της έκθεσης και της επιφάνειας επίθεσης ενός οργανισμού ή ευρύτερου δικτύου.

Η εργασία περιλαμβάνει πρακτική χρήση των εργαλείων για την αναζήτηση και αξιολόγηση εκτεθειμένων υποδομών, την ανάλυση ευπαθειών που μπορούν να εκμεταλλευτούν επιτιθέμενοι, καθώς και προτάσεις για τη θωράκιση και διαχείριση των κινδύνων που προκύπτουν.

Τέλος, αναδεικνύεται η σημασία της συνεχούς παρακολούθησης και ηθικής χρήσης των εργαλείων αυτών, προς όφελος της ασφάλειας και προστασίας των ψηφιακών συστημάτων.

Επιπλέον ιδέες:

1. Bitsy Security Quests – Ανάπτυξη παιχνιδιών κυβερνοασφάλειας με Bitsy
2. Gamified Cyber LLMs – Χρήση Jupyter/Hugging Face για παιχνιδοποιημένα LLM
3. Interactive Cyber Books – Βιβλία με Talefy AI για ιδιωτικότητα και ασφάλεια
4. Terminal LLM Games – Διαδραστικά παιχνίδια σε τερματικό με Ollama (με κώδικα)
5. Cyber Training Games – Εκπαιδευτικά σενάρια μέσω πλατφόρμας Adeptly.ai
6. Cyber Escape Rooms – Δημιουργία Escape Rooms με roomescapemaker.com
7. Phishing via LLM – Προσομοιώσεις phishing επιθέσεων με LLMs

8. OSINT & Shodan Scans – Ανάλυση ευπαθειών με Python και Shodan
9. Gandalf LLM for Awareness – Εικονικός βοηθός για κρυπτογραφία και ασφάλεια
10. LLM + Google Forms Escape – Ψηφιακά escape rooms με LLM και Google Forms
11. Deck.Toys Cyber Paths – Δημιουργία μαθησιακών διαδρομών στο Deck.Toys
12. DeepFake Awareness Games – Παραγωγή DeepFake για ευαισθητοποίηση σε παραπληροφόρηση

Θεματική Περιοχή Ι. Διαγωνισμοί Capture the Flag, Cyber Ranges και Τεχνικές Παιχνιδοποίησης στο Πεδίο της Κυβερνοασφάλειας

Στην σημερινή εποχή έχει μεγαλώσει η ανάγκη για καταρτισμένο ανθρώπινο δυναμικό στο πεδίο της κυβερνοασφάλειας. Για τον λόγο αυτό η εκπαίδευση και η εξοικείωση με το ευρύ φάσμα της κυβερνοασφάλειας είναι μια σημαντική ανάγκη στον χώρο της πληροφορικής, ωστόσο με ανάγκη επέκτασης και σε άλλους κλάδους. Αναπόφευκτα ο ανθρώπινος παράγοντας βρίσκεται στο επίκεντρο καθώς είναι απαραίτητη η εξοικείωση και η πρακτική προσέγγιση στα διάφορα θέματα που σχετίζονται με την κυβερνοασφάλεια.

Τα τελευταία χρόνια παρουσιάζονται όλο και περισσότερο προσεγγίσεις όπως αυτές των προκλήσεων Capture The Flag (CTF). Οι προκλήσεις CTF είναι μια νέα προσέγγιση που μπορεί να αξιοποιηθεί για την παρουσίαση σεναρίων και μπορεί να ενισχύσει την εκπαιδευτική διαδικασία. Οι προκλήσεις Capture the Flag εισαγάγουν τεχνικές παιχνιδοποίησης στην εκπαιδευτική διαδικασία προσφέροντας κίνητρα που βοηθούν στοιχεία της εμβύθισης και τη συστηματική ενασχόληση των εκπαιδευομένων. Επιπλέον τα Cyber Ranges αποτελούν μια καινοτόμα μέθοδος προσομοίωσης ψηφιακών υποδομών και την πραγματοποίηση ρεαλιστικών σεναρίων όπου οι συμμετέχοντες είναι ελεύθεροι να αλληλοεπιδράσουν με το ψηφιακό περιβάλλον. Σκοπός των πτυχιακών εργασιών που εντάσσονται σε αυτή την θεματική περιοχή είναι η δημιουργία προκλήσεων CTF (Capture the Flag), την δημιουργία Cyber Range ή τον συνδυασμό τους με σκοπό την εκπαίδευση στο προαναφερθέν πεδίο και ευρύτερα. **Λέξεις Κλειδιά:** CTF, Capture the Flag, Cyber Range, Gamification, Hands-on Labs

Ενδεικτική Βιβλιογραφία:

Creutzburg, R. (2018). Cybersecurity and Forensic Challenges-A Bibliographic Review. Electronic Imaging, 2018(6), 100-1.

Davis, A., Leek, T., Zhivich, M., Gwinnup, K., & Leonard, W. (2014). The Fun and Future of {CTF}. In 2014 {USENIX} Summit on Gaming, Games, and Gamification in Security Education (3GSE 14).

Mirkovic, J., & Peterson, P. A. (2014). Class capture-the-flag exercises. In 2014 {USENIX} Summit on Gaming, Games, and Gamification in Security Education (3GSE 14).

Karagiannis, S., Maragkos-Belmpas, E., & Magkos, E. (2020, September). An Analysis and Evaluation of Open Source Capture the Flag Platforms as Cybersecurity e-Learning Tools. In IFIP World Conference on Information Security Education (pp. 61-77). Springer, Cham.

Yamin, M. M., Katt, B., & Gkioulos, V. (2020). Cyber ranges and security testbeds: Scenarios, functions, tools and architecture. Computers & Security, 88, 101636.

Pham, C., Tang, D., Chinen, K. I., & Beuran, R. (2016, December). Cyris: A cyber range instantiation system for facilitating security training. In Proceedings of the Seventh Symposium on Information and Communication Technology (pp. 251-258).

Vykopal, J., Ošlejšek, R., Čeleda, P., Vizvary, M., & Tovarňák, D. (2017). Kypo cyber range: Design and use cases.

Pham, C., Tang, D., Chinen, K. I., & Beuran, R. (2016, December). Cyris: A cyber range instantiation system for facilitating security training. In Proceedings of the Seventh Symposium on Information and Communication Technology (pp. 251-258).

Θεματική Περιοχή ΙΙ. Τεχνικές Ανίχνευσης Κυβερνοεπιθέσεων και Περιστατικών στην Ασφάλεια Πληροφοριών

Η διαχείριση των περιστατικών ασφάλειας και η αντιμετώπιση των κυβερνοεπιθέσεων στην σημερινή εποχή έχει εξελιχθεί από μια προληπτική διαδικασία σε διαδικασία υψηλής αλληλεπίδρασης. Ωστόσο, οι σύγχρονες τεχνικές που μπορούν να εφαρμοστούν δεν αξιοποιούνται πλήρως από τους οργανισμούς καθώς είναι αναγκαία η παραμετροποίηση και η ειδικευμένη κατάρτιση που συνήθως υπολείπεται. Με βάση τα προηγούμενα, το εκπαιδευτικό πλαίσιο περιορίζεται συνήθως στις τεχνικές επιθέσεων χωρίς να περιέχουν πρακτικές ασκήσεις όσον αφορά την άμυνα.

Στόχος των πτυχιακών αυτής της θεματικής περιοχής είναι να αναλυθούν, να εφαρμοστούν και να επεκταθούν οι βέλτιστες και καινοτόμες μέθοδοι στην αναγνώριση επιθέσεων καθώς και της καταγραφής περιστατικών κατά την διάρκεια κυβερνοεπιθέσεων, αλλά και οι διαδικασίες που αφορούν στην πρόληψη. Οι διαδικασίες αυτές συνήθως περιλαμβάνουν την εφαρμογή εργαλείων και μεθοδολογιών με βάση διάφορα σενάρια χρήσης που προτείνονται στα διάφορα πεδία όπως πχ. έξυπνες πόλεις (smart cities) τις κρίσιμες υποδομές και την διαχείριση περιστατικών (incident response).

Λέξεις Κλειδιά: Intrusion Detection Systems (IDS), SIEM (System Information and Event Management), Auditing, Certification, Security Controls, Vulnerability assessment, Threat Hunting, Blue Teaming, IBM QRadar, Splunk, Wazuh, Lynis, Open Scap, ELK Stack, Incident Response

Ενδεικτική Βιβλιογραφία:

Bhatt, S., Manadhata, P. K., & Zomlot, L. (2014). The operational role of security information and event management systems. IEEE security & Privacy, 12(5), 35-41.

Vielberth, M., Glas, M., Dietz, M., Karagiannis, S., Magkos, E., & Pernul, G. (2021, July). A Digital Twin-Based Cyber Range for SOC Analysts. In IFIP Annual Conference on Data and Applications Security and Privacy (pp. 293-311). Springer, Cham.

Hamdani, S. W. A., Abbas, H., Janjua, A. R., Shahid, W. B., Amjad, M. F., Malik, J., ... & Khan, A. W. (2021). Cybersecurity Standards in the Context of Operating System: Practical Aspects, Analysis, and Comparisons. ACM Computing Surveys (CSUR), 54(3), 1-36.

Karagiannis, S., Manso, M., Magkos, E., Ribeiro, L. L., & Campos, L. (2021, July). Automated and On-Demand Cybersecurity Certification. In 2021 IEEE International Conference on Cyber Security and Resilience (CSR) (pp. 174-179). IEEE.

Bikmukhamedov, R. F., & Nadeev, A. F. (2020). Generative transformer framework for network traffic generation and classification. T-Comm-Телекоммуникации и Транспорт, 14(11).

Sekharan, S. S., & Kandasamy, K. (2017, March). Profiling SIEM tools and correlation engines for security analytics. In 2017 International Conference on Wireless Communications, Signal Processing and Networking (WiSPNET) (pp. 717-721). IEEE.

Θεματική Περιοχή ΙΙΙ. Τεχνική Ανάλυση και Προσομοίωση Κυβερνοεπιθέσεων

Η τεχνική προσομοίωσης κυβερνοεπιθέσεων (adversary emulation) αξιοποιεί τις τακτικές, τις τεχνικές και τις διαδικασίες (Tactics, Techniques and Procedures - TTPs) για την ανάλυση και την εκτέλεση ρεαλιστικών σεναρίων κυβερνοεπιθέσεων. Σκοπός των πτυχιακών αυτής της θεματικής περιοχής είναι η ανάλυση των υφιστάμενων κυβερνοεπιθέσεων ή η δημιουργία προσομοιώσεων σε ένα ευρύ τεχνολογικό φάσμα που περιλαμβάνει επιθέσεις σε ασύρματα δίκτυα, δίκτυα αισθητήρων ή ψηφιακών υπηρεσιών μεταξύ άλλων.

Λέξεις Κλειδιά: Intrusion Adversary Emulation, Red Team Emulation, Red Team Assessment, Malware Analysis, Ethical Hacking, MITRE ATT&CK

Ενδεικτική Βιβλιογραφία:

Applebaum, A., Miller, D., Strom, B., Foster, H., & Thomas, C. (2017, July). Analysis of automated adversary emulation techniques. In Proceedings of the Summer Simulation Multi-Conference (pp. 1-12).

Miller, D., Alford, R., Applebaum, A., Foster, H., Little, C., & Strom, B. (2018). Automated adversary emulation: A case for planning and acting with unknowns. MITRE CORP MCLEAN VA MCLEAN.

Yoo, J. D., Park, E., Lee, G., Ahn, M. K., Kim, D., Seo, S., & Kim, H. K. (2020). Cyber Attack and Defense Emulation Agents. Applied Sciences, 10(6), 2140.

Applebaum, A., Miller, D., Strom, B., Korban, C., & Wolf, R. (2016, December). Intelligent, automated red team emulation. In Proceedings of the 32nd Annual Conference on Computer Security Applications (pp. 363-373).

Kuppa, A., Aouad, L., & Le-Khac, N. A. (2021, August). Linking CVE's to MITRE ATT&CK Techniques. In The 16th International Conference on Availability, Reliability and Security (pp. 112).

Alexander, O., Belisle, M., & Steele, J. (2020). MITRE ATT&CK® for industrial control systems: Design and philosophy. The MITRE Corporation: Bedford, MA, USA.

Θεματική Περιοχή IV. Μάθηση με βάση το παιχνίδι (Game Based Learning)

Οι εκπαιδευτικές μεθοδολογίες στην σημερινή εποχή κατευθύνονται ως νέα τάση στην αξιοποίηση της μάθησης με βάση το παιχνίδι. Το συγκεκριμένο πεδίο αποτελεί πρόκληση καθώς η αξιοποίηση ψυχαγωγικού λογισμικού στην εκπαίδευση είναι ένα ενεργό ερευνητικό πεδίο με πολλές προκλήσεις. Από την μια πλευρά οι εκπαιδευόμενοι πρέπει να έχουν στοιχεία υψηλής εμβύθισης και κίνητρα για να συμμετέχουν ενεργά και δραστήρια αλλά και ταυτόχρονα οι συγκεκριμένες τακτικές αξιοποίησης παιχνιδιών να πετυχαίνουν τον σκοπό σε σχέση με την διαδικασία μάθησης. Πιο συγκεκριμένα παραμένουν πολλές οι ερευνητικές προκλήσεις στο πεδίο της ενημερότητας στην ασφάλεια πληροφοριών (security awareness) αλλά και γενικότερα στο πεδίο της κυβερνοασφάλειας με βάση τα προηγούμενα. Σκοπός των εργασιών αυτής της θεματικής περιοχής είναι ο σχεδιασμός, η δημιουργία εκπαιδευτικής μεθοδολογίας και η αξιοποίηση της μάθησης με βάση το παιχνίδι - Game Based Learning (GBL) και τέλος η δημιουργία παιχνιδιών ή διαδραστικών μέσων στο πεδίο της ασφάλειας πληροφοριών.

Λέξεις Κλειδιά: Game Based Learning (GBL), Tabletops, Security Awareness, Alternate Reality Games (ARG), Escape Rooms, Interactive Books

Ενδεικτική Βιβλιογραφία:

Hart, S., Margheri, A., Paci, F., & Sassone, V. (2020). Riskio: A serious game for cyber security awareness and education. Computers & Security, 95, 101827.

Karagiannis, S., Papaioannou, T., Magkos, E., & Tsohou, A. (2020, November). Game-Based Information Security/Privacy Education and Awareness: Theory and Practice. In European, Mediterranean, and Middle Eastern Conference on Information Systems (pp. 509-525). Springer, Cham.

Shostack, A. (2014). Elevation of privilege: Drawing developers into threat modeling. In 2014 {USENIX} Summit on Gaming, Games, and Gamification in Security Education (3GSE 14).

Jøsang, A., Stray, V., & Rygge, H. (2020, September). Threat Poker: Gamification of Secure Agile. In IFIP World Conference on Information Security Education (pp. 142-155). Springer, Cham.

Gondree, M., Peterson, Z. N., & Denning, T. (2013). Security through play. IEEE Security & Privacy, 11(3), 64-67.

Θεματική Περιοχή V. Μηχανική Μάθηση στην Ασφάλεια Συστημάτων και την Ιδιωτικότητα

Η μηχανική μάθηση και η τεχνητή νοημοσύνη συνολικά βρίσκει εφαρμογή σε διάφορα τεχνολογικά πεδία. Η συγκεκριμένη θεματική περιοχή ασχολείται με εφαρμογές της μηχανικής μάθησης στα πεδία της ασφάλειας και της ιδιωτικότητας όπως τον εντοπισμό κακόβουλων ενεργειών, την κατηγοριοποίηση δικτυακής κίνησης (Deep Packet Inspection), την ανάλυση και διαμοιρασμό δεδομένων που προέρχονται από την ανάλυση (threat intelligence, sharing and distribution). Επιπλέον είναι σημαντική η ανάλυση δεδομένων με επίκεντρο την ιδιωτικότητα και επομένως η θεματική περιοχή αυτή ασχολείται με την διατήρηση της ιδιωτικότητας σε προσωπικά και ευαίσθητα δεδομένα με την ενεργοποίηση μαθηματικών μοντέλων ώστε να αξιοποιούνται δεδομένα στην έρευνα χωρίς να εκτείνονται τα προσωπικά δεδομένα. Η θεματική περιοχή αυτή ασχολείται με όλα τα εργαλεία λογισμικού που μπορούν να αξιοποιηθούν και τις αντίστοιχες βιβλιοθήκες (ενδεικτικά: Python, PyTorch[8], Tensorflow[9], NFStream[10], ELK Stack[11], Opacus[12], ARX[13], Web-MPC[14])

Λέξεις Κλειδιά: Machine Learning, Deep Learning, Deep Packet Inspection, ML IDS, Differential Privacy, Privacy Validation, Data Analysis, Behavioral Analysis, Data Anonymization, Data Privacy, Privacy Preservation, Privacy Enhancing Tools (PETs), Secure Multi-party Computation (MPC), MISP

Ενδεικτική Βιβλιογραφία:

Aouini, Z., & Pekar, A. (2022). NFStream: A flexible network data analysis framework. Computer Networks, 204, 108719.

[8] https://pytorch.org/
[9] https://tensorflow.org/
[10] https://nfstream.org/
[11] https://www.elastic.co/what-is/elasticsearch-machine-learning
[12] https://github.com/pytorch/opacus
[13] https://arx.deidentifier.org/
[14] https://github.com/multiparty/web-mpc

Ali, Z., Hussain, F., Ghazanfar, S., Husnain, M., Zahid, S., & Shah, G. A. (2021, November). A Generic Machine Learning Approach for IoT Device Identification. In 2021 International Conference on Cyber Warfare and Security (ICCWS) (pp. 118-123). IEEE.

Zhou, J., Feng, Y., Wang, Z., & Guo, D. (2021). Using secure multi-party computation to protect privacy on a permissioned blockchain. Sensors, 21(4), 1540.

Liu, J., Tian, Y., Zhou, Y., Xiao, Y., & Ansari, N. (2020). Privacy preserving distributed data mining based on secure multi-party computation. Computer Communications, 153, 208-216.

Lapets, A., Jansen, F., Albab, K. D., Issa, R., Qin, L., Varia, M., & Bestavros, A. (2018, June). Accessible privacy-preserving web-based data analysis for assessing and addressing economic inequalities. In Proceedings of the 1st ACM SIGCAS Conference on Computing and Sustainable Societies (pp. 1-5).

Qin, L., Lapets, A., Jansen, F., Flockhart, P., Albab, K. D., Globus-Harris, I., ... & Varia, M. (2019). From usability to secure computing and back again. In Fifteenth Symposium on Usable Privacy and Security (SOUPS 2019) (pp. 191-210).

Thakkar, A., & Lohiya, R. (2021). A review on machine learning and deep learning perspectives of IDS for IoT: recent updates, security issues, and challenges. Archives of Computational Methods in Engineering, 28(4), 3211-3243.

Çakmakçı, S. D., Hutschenreuter, H., Maeder, C., & Kemmerich, T. (2021, June). A framework for intelligent DDoS attack detection and response using SIEM and ontology. In 2021 IEEE International Conference on Communications Workshops (ICC Workshops) (pp. 1-6). IEEE.

LaueA, T., KleckerB, T., KleinerA, C., & DetkenB, K. O. (2022). A SIEM Architecture for Advanced Anomaly Detection.

Subramanian, K., & Meng, W. (2021, December). Threat Hunting Using Elastic Stack: An Evaluation. In 2021 IEEE International Conference on Service Operations and Logistics, and Informatics (SOLI) (pp. 1-6). IEEE.

Θεματική Περιοχή VI. Τεχνικές Ανάλυσης Τρωτών σημείων κατά την Ανάπτυξη Λογισμικού και Κώδικα. Τεχνικές Πιστοποίησης

Η σύγχρονη κοινωνία και τα ψηφιακά συστήματα που αξιοποιούνται καθημερινά έχουν οικοδομηθεί από πολύπλοκα συστήματα που αποτελούν μέρος ενός πιο περίπλοκου εξελιγμένου συστήματος όπου απαιτείται συνεργασία μεταξύ πολλών ανεξάρτητων συστημάτων. Η θεματική περιοχή αυτή σχετίζεται με τις τεχνικές εκτίμησης ευπαθειών ή αλλιώς Vulnerability Assessment και τις διαδικασίες προσδιορισμού, αναγνώρισης, ταξινόμησης και ιεράρχησης ευπαθειών σε συστήματα υπολογιστών, εφαρμογές και υποδομές δικτύου. Η θεματική περιοχή καλύπτει τα πεδία που έχουν σχέση με τις ευπάθειες σε όλα τα επίπεδα, από το επίπεδο σχεδιασμού,

ανάπτυξης λογισμικού καθώς και στο πραγματικό περιβάλλον. Επομένως εκτείνεται στα εξής πεδία που εκτείνονται από το vulnerability assessment στις ευπάθειες κώδικα, στο CI/CD και στα πεδία των DevOps και SecDevOps.

Λέξεις Κλειδιά: Code Vulnerabilities, SAST analysis, DAST analysis, Nmap, Vulnerability Scanners, OWASP, Certification, OpenVAS, Nikto, WPScan, Lynis, Wauzh, Nettacker, Archerysec[15]

Ενδεικτική Βιβλιογραφία:

Karangle, N., Mishra, A. K., & Khan, D. A. (2019, July). Comparison of Nikto and Uniscan for measuring URL vulnerability. In 2019 10th International Conference on Computing, Communication and Networking Technologies (ICCCNT) (pp. 1-6). IEEE.

Karagiannis, S., Manso, M., Magkos, E., Ribeiro, L. L., & Campos, L. (2021, July). Automated and On-Demand Cybersecurity Certification. In 2021 IEEE International Conference on Cyber Security and Resilience (CSR) (pp. 174-179). IEEE.

Nikoloudakis, Y., Pallis, E., Mastorakis, G., Mavromoustakis, C. X., Skianis, C., & Markakis, E. K. (2019). Vulnerability assessment as a service for fog-centric ICT ecosystems: A healthcare use case. Peer-to-Peer Networking and Applications, 12(5), 1216-1224.

Kamongi, P., Kotikela, S., Kavi, K., Gomathisankaran, M., & Singhal, A. (2013, June). Vulcan: Vulnerability assessment framework for cloud computing. In 2013 IEEE 7th international conference on software security and reliability (pp. 218-226). IEEE.

Makino, Y., & Klyuev, V. (2015, September). Evaluation of web vulnerability scanners. In 2015 IEEE 8th International Conference on Intelligent Data Acquisition and Advanced Computing Systems: Technology and Applications (IDAACS) (Vol. 1, pp. 399-402). IEEE.

Bobbert, Y., & Chtepen, M. (2021). Findings and Core Practices in the Domain of CI/CD and DevOps on Security Compliance. In Strategic Approaches to Digital Platform Security Assurance (pp. 308-313). IGI Global.

Θεματική Περιοχή VII. Δίκτυα Ανωνυμίας και Κρυπτογράφηση

Τα ανώνυμα συστήματα επικοινωνίας P2P αποτελούν peer-to-peer κατανεμημένες εφαρμογές στις οποίες οι κόμβοι που χρησιμοποιούνται για την κοινή χρήση πόρων, ή οι συμμετέχοντες είναι ανώνυμοι ή ψευδώνυμοι. Η ανωνυμία των συμμετεχόντων συνήθως επιτυγχάνεται με ειδικά δίκτυα επικάλυψης δρομολόγησης που κρύβουν τη φυσική θέση κάθε κόμβου από άλλους συμμετέχοντες (πχ. TOR, i2p κλπ). Το ενδιαφέρον για ανώνυμα συστήματα P2P έχει αυξηθεί τα τελευταία χρόνια για πολλούς λόγους, που κυμαίνονται από την επιθυμία κοινής χρήσης αρχείων χωρίς αποκάλυψη της ταυτότητας του δικτύου μέχρι την αξιοποίηση τους για P2P συναλλαγές και

[15] https://github.com/archerysec/archerysec

την αξιοποίηση του Blockchain σε διάφορες εφαρμογές. Η θεματική επίσης περιλαμβάνει θέματα όπως το Net Neutrality, τα Privacy Enhancing Tools (PETS), distributed file sharing και συνολικά το democratization. Σκοπός της θεματικής περιοχής είναι να αναλυθούν ή να υλοποιηθούν εργαλεία και τεχνικές που αξιοποιούν τα παραπάνω.

Στο πεδίο της κυβερνοασφάλειας και της διαχείρισης πληροφορίας υπάρχει περιθώριο ανάπτυξης υποστηρικτικού λογισμικού ώστε οι οργανισμοί να συνάπτουν στους διεθνείς κανονισμούς. Πιο συγκεκριμένα αναπτύσσονται λογισμικά που αξιοποιούνται στα πεδία της κυβερνοασφάλειας και της διασφάλισης της ιδιωτικότητας μέσω αλγορίθμων MPC (Secure Multiparty Computation) και της κρυπτογραφίας (πχ. hashing functions). Επιπλέον αναπτύσσονται λογισμικά ή παραμετροποιούνται ώστε να αποτελέσουν εργαλειοθήκες (toolkits) ή σουίτες λογισμικών που ενισχύουν την αυτοματοποίηση διαδικασιών ή της ενίσχυσης της ασφάλειας και της ιδιωτικότητας. Σκοπός των πτυχιακών αυτής της θεματικής περιοχής είναι η ανάπτυξη λογισμικού ή κώδικα που εξυπηρετεί την ενίσχυση της ασφάλειας ή της ιδιωτικότητας. Τα λογισμικά που αναπτύσσονται μπορούν να περιλαμβάνουν την δημιουργία ή επέκταση λογισμικού ανοικτού κώδικα στα πλαίσια της ανίχνευσης ευπαθειών, επιθέσεων ή την ανάπτυξη λογισμικού διασφάλισης και ενίσχυσης της ιδιωτικότητας. Επιπλέον παρόμοια πεδία που εμπεριέχουν καινοτόμες τεχνολογίες αποτελούν περιοχές όπως την ανάπτυξη εφαρμογών στο Blockchain και των Distributed Ledgers Technology (DLT).

Μερικά από τα εργαλεία που μπορούν να αξιοποιηθούν είναι το ElasticSearch[16] και το ELK Stack (Elastic, Logstash, Kibana) για την αναζήτηση των logs ή εργαλεία απεικόνισης όπως το Grafana[17]. Επιπλέον μπορούν να αξιοποιηθούν εργαλεία όπως πως το Suricata[18], το Snort[19] ή εργαλεία για την δημιουργία Honeypots (πχ. T-Pot[20]) μεταξύ άλλων.

Λέξεις Κλειδιά: P2P, Decentralized Networks, Onion Routing, TOR, i2p, Anonymity, PETS, Net Neutrality, Blockchain, Democratization, Anonymous Networks, Decentralized DNS, Encryption, Cryptography, Mix Networks, Decentralized Storage, Software Development, Secure Multiparty Computation (MPC), Blockchain Development, Privacy Enhancing Technologies (PETs), ZeroKnowledge Proof, API Development, Vulnerability Assessment, Solidity, Hyperledger, Ethereum

Ενδεικτική Βιβλιογραφία:

Lindell, Y. (2020). Secure Multiparty Computation (MPC). IACR Cryptol. ePrint Arch., 2020, 300.

Saraf, C., & Sabadra, S. (2018, May). Blockchain platforms: A compendium. In 2018 IEEE International Conference on Innovative Research and Development (ICIRD) (pp. 1-6). IEEE.

[16] https://www.elastic.co/
[17] https://grafana.com/
[18] https://github.com/OISF/suricata
[19] https://www.snort.org/
[20] T-Pot

Nikoloudakis, Y., Kefaloukos, I., Klados, S., Panagiotakis, S., Pallis, E., Skianis, C., & Markakis, E. K. (2021). Towards a Machine Learning Based Situational Awareness Framework for Cybersecurity: An SDN Implementation. Sensors, 21(14), 4939.

Karagiannis, S., Manso, M., Magkos, E., Ribeiro, L. L., & Campos, L. (2021, July). Automated and On-Demand Cybersecurity Certification. In 2021 IEEE International Conference on Cyber Security and Resilience (CSR) (pp. 174-179). IEEE.